PANDUAN GOVERNANCE, RISK & COMPLIANCE (GRC)

# PANDUAN KEPATUHAN KEAMANAN DATA & REGULASI BISNIS

Pemenuhan UU PDP No. 27/2022, Standar ISO/IEC 27001:2022 & Kerangka Kerja NIST v1.0

**Pentingnya Kepatuhan (Compliance):** Kepatuhan keamanan siber bukan sekadar pemenuhan hukum, tetapi merupakan fondasi kepercayaan pelanggan. Kegagalan mematuhi UU Perlindungan Data Pribadi (UU PDP) dapat berakibat denda administratif hingga 2% dari pendapatan tahunan serta sanksi pidana.

## 1. Kerangka Kepatuhan UU No. 27 Tahun 2022 (UU PDP)

Kewajiban utama organisasi sebagai Pengendali Data Pribadi (*Data Controller*) dalam mengelola data pelanggan dan karyawan:

| Prinsip Utama | Persyaratan Hukum | Implementasi Operasional |
|---|---|---|
| **Dasar Pemrosesan** | Memiliki persetujuan eksplisit (*Consent*) atau kewajiban kontraktual yang sah. | Sediakan formulir persetujuan transparan pada aplikasi & web. |
| **Hak Subjek Data** | Mengakomodasi hak menghapus data (*Right to be Forgotten*), merubah, dan mengakses data. | Buat Prosedur Operasional Standar (SOP) layanan permintaan subjek data. |
| **Pejabat PDP (DPO)** | Menunjuk *Data Protection Officer* jika memproses data skala besar atau berisiko tinggi. | Tetapkan personil penanggung jawab kepatuhan data internal. |
| **Pelaporan Kebocoran** | Wajib melaporkan insiden kegagalan perlindungan data maksimal **3 x 24 jam**. | Susun alur penanganan insiden & laporan resmi ke lembaga pengawas. |

## 2. Standar Manajemen Keamanan Informasi (ISO/IEC 27001:2022)

Implementasi Sistem Manajemen Keamanan Informasi (SMKI / ISMS) berbasis standar internasional:

### Kontrol Organisasional

Penetapan kebijakan keamanan informasi, pembagian peran dan tanggung jawab, serta pengawasan akses pihak ketiga/vendor.

### Kontrol Kelayakan Sumber Daya

Pemeriksaan latar belakang (*background check*) karyawan baru, pelatihan kesadaran siber berkala, dan prosedur *offboarding*.

### Kontrol Keamanan Fisik

Pembatasan akses fisik ke ruang server/data center, CCTV, kontrol suhu, serta perlindungan dari ancaman lingkungan.

### Kontrol Teknologis

Manajemen hak akses, enkripsi data, manajemen kerentanan (*vulnerability management*), dan pemantauan log sistem.

## 3. Kerangka Kerja Keamanan NIST Cybersecurity Framework 2.0

Penerapan 6 fungsi NIST CSF untuk menyelaraskan keamanan teknis dengan strategi bisnis:

| Fungsi NIST | Fokus Aktivitas Organisasi | Output Kepatuhan |
|---|---|---|
| **Govern (Kelola)** | Penetapan prioritas bisnis, kebijakan, dan manajemen risiko siber. | Dokumen Kebijakan & Profil Risiko Organisasi. |
| **Identify (Identifikasi)** | Inventarisasi aset data, perangkat lunak, hardware, dan rantai pasok. | Register Aset Informasi & Pemetaan Data. |
| **Protect (Proteksi)** | Penerapan kontrol akses, enkripsi, pelatihan karyawan, dan hardening. | Penerapan MFA, WAF, Enkripsi AES-256. |
| **Detect (Deteksi)** | Pemantauan aktivitas mencurigakan dan pemindaian kerentanan. | Penggunaan SIEM / EDR & Log Monitoring. |
| **Respond (Respon)** | Tindakan penanggulangan insiden dan isolasi ancaman. | Tim Tanggap Insiden Siber (CSIRT) & SOP Respon. |
| **Recover (Pulihkan)** | Pemulihan fungsi operasional dan restorasi data cadangan. | Rencana Kelangsungan Bisnis (*BCP/DRP*). |

## 4. Checklist Penilaian Diri Kepatuhan Berkala (Self-Assessment)

Gunakan daftar periksa kepatuhan berikut untuk kesiapan audit internal maupun eksternal:

- [ ] **Dokumentasi Kebijakan:** Memiliki dokumen Privacy Policy, Terms of Service, dan Internal Security Policy yang diperbarui.
- [ ] **Data Protection Impact Assessment (DPIA):** Menjalankan analisis dampak perlindungan data sebelum meluncurkan aplikasi/fitur baru.
- [ ] **Perjanjian Pemrosesan Data (DPA):** Penandatanganan klausul perlindungan data dengan seluruh vendor pihak ketiga.
- [ ] **Uji Penetrasi Berkala (PenTest):** Menjalankan uji penetrasi sistem oleh pihak independen minimal 1 kali dalam setahun.
- [ ] **Audit Hak Akses:** Melakukan evaluasi berkala terhadap hak akses superadmin dan akun istimewa (*privileged accounts*).